

RENCANA UJI KEAMANAN INFORMASI (TESTING PLAN)

Platform Peminjaman Fasilitas Kampus - IPB Space
Mata Kuliah Keamanan Informasi (KOM1315) - Semester Genap 2026

Disusun Oleh: Kelompok 11	Dosen Pengampu 1: Dr. Shelve Nidya Neyman
1. Daffa Aulia M. S. (G6401231028)	Dosen Pengampu 2: Endang P. Giri, M.Kom
2. Hakim Ilyas Azhar (G6401231077)	Target Framework: Pytest (Sisi Backend)
3. Kivi Adelio (G6401231047)	Sistem Database: PostgreSQL (Docker Isolated)

1. Tujuan Pengujian

Pengujian ini bertujuan untuk memvalidasi secara menyeluruh seluruh implementasi kontrol keamanan berlapis (Defense in Depth) pada kode sumber IPB Space. Cakupan pengujian meliputi keandalan fungsi Autentikasi (JWT), akurasi Otorisasi berbasis peran (RBAC), validasi kepemilikan data untuk mencegah Insecure Direct Object References (IDOR), pencatatan jejak audit (Audit Trail) via Structlog, proteksi celah OWASP Top 10, serta integritas mutlak dari Digital Signature berbasis Kurva Eliptik Ed25519 pada QR Code tiket peminjaman.

2. Testing Environment

- Bahasa & Framework Server: Python 3.10+ / FastAPI REST API.
- Database Sandbox: PostgreSQL 15 berjalan di dalam Docker Private Network (hanya menerima koneksi dari Backend).
- Environment Variables Configuration: Memanfaatkan file .env.test untuk memuat variabel tiruan (JWT_SECRET, SIGNING_PUBLIC_KEY) guna mengisolasi proses pengujian dari data produksi.

3. Minimum Data Testing

Untuk menjalankan skenario otomatis, database diisi terlebih dahulu (seeded status) dengan entitas minimal berikut:

- Akun Civitas: mahasiswa_test@apps.ipb.ac.id (Password Hash: Bcrypt).
- Akun Facility Manager: manager_gww@apps.ipb.ac.id (Password Hash: Bcrypt).
- Akun Super Admin: superadmin_test@apps.ipb.ac.id (Password Hash: Bcrypt).
- Data Fasilitas: ID Ruang GWW-01 (Graha Widya Wisuda), Status: Available.
- File Dummy: dokumen_izin.pdf (MIME: application/pdf) dan exploit.sh (MIME: text/x-shellscript).

4. Matriks Skenario Authentication (AUTH)

ID Uji	Deskripsi Kasus Uji	Input / Aksi	Ekspektasi Hasil
AUTH-01	Login dengan kredensial valid	Email & password civitas terdaftar benar	HTTP 200 OK, return Access Token & Refresh Token
AUTH-02	Login dengan password salah	Email terdaftar, password diacak	HTTP 401 Unauthorized, token gagal diterbitkan
AUTH-03	Login dengan email tidak terdaftar	Email acak belum diregistrasi, password benar	HTTP 401 Unauthorized, pesan error jelas
AUTH-04	Akses protected endpoint tanpa token	Request GET ke /api/v1/bookings/my-tickets tanpa header auth	HTTP 401 Unauthorized, akses diblokir middleware
AUTH-05	Akses endpoint dengan token kedaluwarsa	Menyertakan Access Token yang telah melewati batas waktu 7 jam	HTTP 401 Unauthorized, memicu auto-refresh token di frontend

AUTH-06	Akses endpoint dengan token hasil manipulasi	Mengubah karakter payload string JWT secara paksa	HTTP 401/403, sistem gagal memvalidasi tanda tangan JWT
AUTH-07	Penerbitan Access Token baru via Refresh Token	Kirim Refresh Token valid ke endpoint /auth/refresh	HTTP 200 OK, Access Token baru berhasil diterbitkan
AUTH-08	Penerbitan token dengan Refresh Token kedaluwarsa	Kirim Refresh Token yang telah melewati masa aktif 7 hari	HTTP 401 Unauthorized, pengguna dipaksa login ulang
AUTH-09	Proses penanganan logout log	Kirim request POST ke endpoint /auth/logout	HTTP 200 OK, token dinonaktifkan di sisi client
AUTH-10	Mitigasi serangan brute force pada login	Melakukan request login gagal sebanyak 10 kali berturut-turut	HTTP 429 Too Many Requests, IP diblokir sementara

5. Matriks Skenario Authorization (AUTO)

ID Uji	Deskripsi Kasus Uji	Input / Aksi	Ekspektasi Hasil
AUTO-01	Civitas mengakses log audit global	Role civitas mengakses /system/logs	HTTP 403 Forbidden, dependensi ensure_is_admin memblokir
AUTO-02	Civitas menyetujui tiket peminjaman	Role civitas mengirim POST ke /bookings/approve	HTTP 403 Forbidden, ditolak oleh sistem otorisasi
AUTO-03	Facility Manager mengakses log audit	Role facility_manager mengakses /system/logs	HTTP 403 Forbidden, hak akses khusus Super Admin
AUTO-04	Tamu tanpa login membuat booking	Pengguna anonim mengirim POST request ke /bookings	HTTP 401 Unauthorized, wajib memiliki token civitas
AUTO-05	IDOR Check: Civitas membatalkan booking user lain	Civitas A menembak ID booking milik Civitas B ke /cancel booking	HTTP 403 Forbidden, Owner Validation menolak eksekusi
AUTO-06	IDOR Check: Civitas melihat tiket user lain	Civitas A meminta data manifes dari ID tiket Civitas B	HTTP 403 Forbidden, akses ditolak karena bukan pemilik data
AUTO-07	IDOR Check: Manager mengubah data ruang luar wilayah	Manager A mencoba memutasi master data gedung milik Manager B	HTTP 403 Forbidden, kepemilikan aset tidak cocok
AUTO-08	Eksekusi CRUD pengguna oleh Admin	Role admin membuat/menghapus data pengguna di sistem	HTTP 200/201 OK, modifikasi data berhasil diterapkan
AUTO-09	Eksekusi persetujuan oleh Facility Manager	Role facility_manager menyetujui peminjaman berstatus pending	HTTP 200 OK, status berubah menjadi APPROVED
AUTO-10	Pengajuan booking valid oleh Civitas	Role civitas mengirim form lengkap ke endpoint /bookings	HTTP 201 Created, objek booking tersimpan di database

6. Matriks Skenario Accounting (ACC)

ID Uji	Deskripsi Kasus Uji	Input / Aksi	Ekspektasi Hasil
ACC-01	Pencatatan log saat login berhasil	Memicu kondisi sukses pada kasus AUTH-01	Berkas app_logs.txt memperbarui baris dengan AUTH_LOGIN_SUCCESS
ACC-02	Pencatatan log saat login gagal	Memicu kondisi gagal pada kasus AUTH-02	Berkas app_logs.txt memperbarui baris dengan AUTH_LOGIN_FAIL
ACC-03	Pencatatan log saat booking dibuat	Memicu kondisi sukses pada kasus AUTO-10	Audit log mencatat event_type: BOOKING_CREATED beserta ID objek
ACC-04	Pencatatan log saat booking disetujui	Memicu kondisi sukses pada kasus AUTO-09	Audit log mencatat event_type: BOOKING_APPROVED secara permanen
ACC-05	Validasi Request Tracing UUID	Melakukan inspeksi terhadap 3 baris aktivitas acak di log	Setiap baris log wajib mengikat nilai string request_id unik
ACC-06	Validasi standardisasi waktu UTC	Memeriksa format penulisan waktu kejadian aktivitas	Timestamp log wajib menggunakan standar zona waktu UTC global
ACC-07	Validasi pencatatan alamat IP asal	Melakukan request melalui IP jaringan eksternal	Kolom ip_address pada file log mencatat alamat IP asli client
ACC-08	Proteksi pembacaan file log ilegal	Role civitas menembak langsung GET ke /system/logs	HTTP 403 Forbidden, file log lokal terisolasi dari publik
ACC-09	Pembacaan berkas log sah oleh Admin	Role admin meminta manifest log melalui gerbang resmi	HTTP 200 OK, memuntahkan isi data JSON log operasional
ACC-10	Pemeriksaan kebocoran data pada log	Membuka teks berkas app_logs.txt secara menyeluruh	Tidak ada password plain-text atau secret key yang bocor di log

7. Skenario Enkripsi dan Proteksi Data Sensitif (PROT)

ID Uji	Deskripsi Kasus Uji	Input / Aksi	Ekspektasi Hasil
PROT-01	Verifikasi kekuatan hashing kata sandi	Melakukan inspeksi data row pada tabel database users	String kata sandi berformat karakter acak Bcrypt (\$2b\$)
PROT-02	Pencegahan kebocoran hash via API	Meminta detail profil civitas melalui response endpoint	Kolom password hash wajib di-filter (tidak ikut keluar ke client)
PROT-03	Uji coba serangan SQLi pada filter search	Memasukkan parameter ' OR '1'='1 ke pencarian fasilitas	HTTP 200 OK hasil kosong, dinetralisir ORM SQLAlchemy 2.0
PROT-04	Uji coba serangan SQLi pada form login	Memasukkan payload injeksi SQL ke dalam kolom email login	HTTP 401 Unauthorized, query dieksekusi aman sebagai literal
PROT-05	Unggah berkas dokumen valid	Mengunggah file dokumen izin.pdf pada form sewa	HTTP 201 Created, file lolos filter MIME-type backend
PROT-06	Unggah berkas berbahaya ekstensi .sh	Mengunggah file skrip exploit.sh ke sistem pengajuan	HTTP 400 Bad Request, sistem memblokir ekstensi ilegal
PROT-07	Unggah berkas berbahaya manipulasi header	Mengubah file php menjadi bertipe samaran image/png	HTTP 400 Bad Request, validasi deep-check MIME gagal
PROT-08	Isolasi variabel kunci rahasia	Memeriksa repositori Git kelompok di GitHub	File .env tidak terkomit, kunci dimuat dari local environment

PROT-09	Pengujian restriksi CORS domain luar	Melakukan request API menggunakan origin domain ilegal	HTTP 400/403 Cross-Origin Blocked, request ditolak server
PROT-10	Pengujian akses CORS domain terpercaya	Melakukan request melalui domain localhost / Vercel resmi	HTTP 200 OK, komunikasi data diizinkan secara penuh

8. Skenario Digital Signature (SIGN)

ID Uji	Deskripsi Kasus Uji	Input / Aksi	Ekspektasi Hasil
SIGN-01	Generasi signature saat tiket disetujui	Memicu perubahan status booking menjadi APPROVED	Kolom digital_signature di DB otomatis terisi kode Base64
SIGN-02	Validasi urutan parameter payload (Serialization)	Mengubah susunan key JSON transaksi sebelum proses signing	Fungsi sort_keys=True memastikan hasil text string tetap identik
SIGN-03	Verifikasi tiket QR Code asli	Kirim request verifikasi token tiket sah ke /verify/{token}	HTTP 200 OK, sistem menampilkan pesan "PERMIT VALID"
SIGN-04	Anti-Tampering: Modifikasi data tiket	Mengubah parameter nama nim/ruangan di dalam string token tiket	HTTP 400 Bad Request, validasi gagal: "PERMIT TIDAK VALID!"
SIGN-05	Anti-Tampering: Modifikasi string signature	Mengubah satu karakter pada tanda tangan digital token	Sistem mendeteksi kerusakan matematis kurva Ed25519, blokir
SIGN-06	Akses workspace validator tiket	Role facility_manager memindai kode QR tiket	HTTP 200 OK, validator berhasil memproses verifikasi data
SIGN-07	Akses verification bypass tanpa public key	Mencoba memverifikasi tiket dengan menghapus public key server	Sistem mendeteksi ketiadaan komponen kunci dan memutus aliran
SIGN-08	Verifikasi dokumen offline via Public Key	Proses dekripsi token tiket hanya menggunakan SIGNING PUBLIC KEY	Verifikasi sukses tanpa perlu memanggil Private Key server
SIGN-09	Mitigasi serangan replay attack tiket	Menggunakan tiket lama yang sudah melewati batas waktu check-in	Sistem menolak tiket dan memberikan info token telah kedaluwarsa
SIGN-10	Pencegahan kerusakan DB akibat sign error	Memicu kegagalan fungsi sign secara paksa (kunci privat korup)	Exception handler menangkap error, transaksi rollback aman

9. Acceptance Criteria (Kriteria Penerimaan)

1. Kriteria Autentikasi: Seluruh kredensial pengguna wajib terlindungi dengan hashing terverifikasi (Bcrypt). Sesi data terisolasi menggunakan JWT dan tertutup dari akses luar tanpa otentikasi.
2. Kriteria Otorisasi: Hak akses terbagi konsisten antar peran (admin, civitas, facility_manager). Tidak ditemukan celah kebocoran data kepemilikan antar-pengguna (Bebas IDOR).
3. Kriteria Integritas: Sistem wajib menolak file berbahaya di luar ketentuan PDF/Gambar dan mampu mengidentifikasi manipulasi data pada tiket QR Code secara instan dengan memunculkan status tidak valid.
4. Kriteria Audit: Setiap aktivitas manipulasi database wajib memicu rekaman log baru pada app_logs.txt lengkap bersama pelacakan UUID request_id.

10. Template Pencatatan Hasil (Test Execution Log)

Berikut adalah format tabel yang digunakan untuk mencatatkan hasil pengujian aktual di dalam laporan akhir kelompok:

ID Uji	Kategori	Respons Sistem / Hasil Riil	Status	Keterangan
			PASS	
			PASS	

			PASS	
...	...	...	...	...